COMPTE RENDU : TP 4.1 – SEGMENTATION ET SÉCURISATION AVEC PFSENSE

1. Objectifs du TP

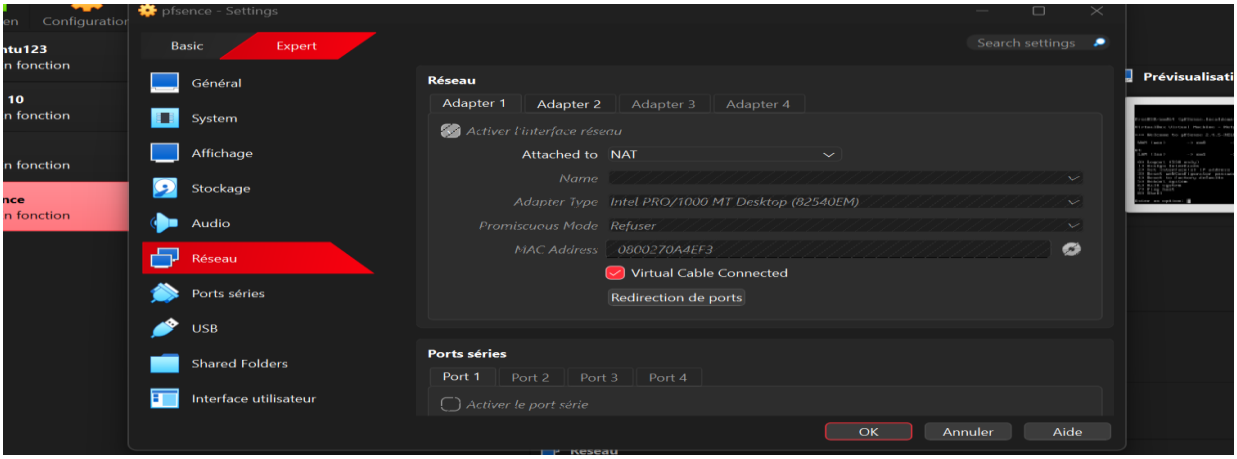
L'objectif est de transformer un réseau ouvert (où toutes les machines communiquent sans restriction) en un environnement segmenté et sécurisé. L'introduction de

pfSense comme pare-feu central permet de :

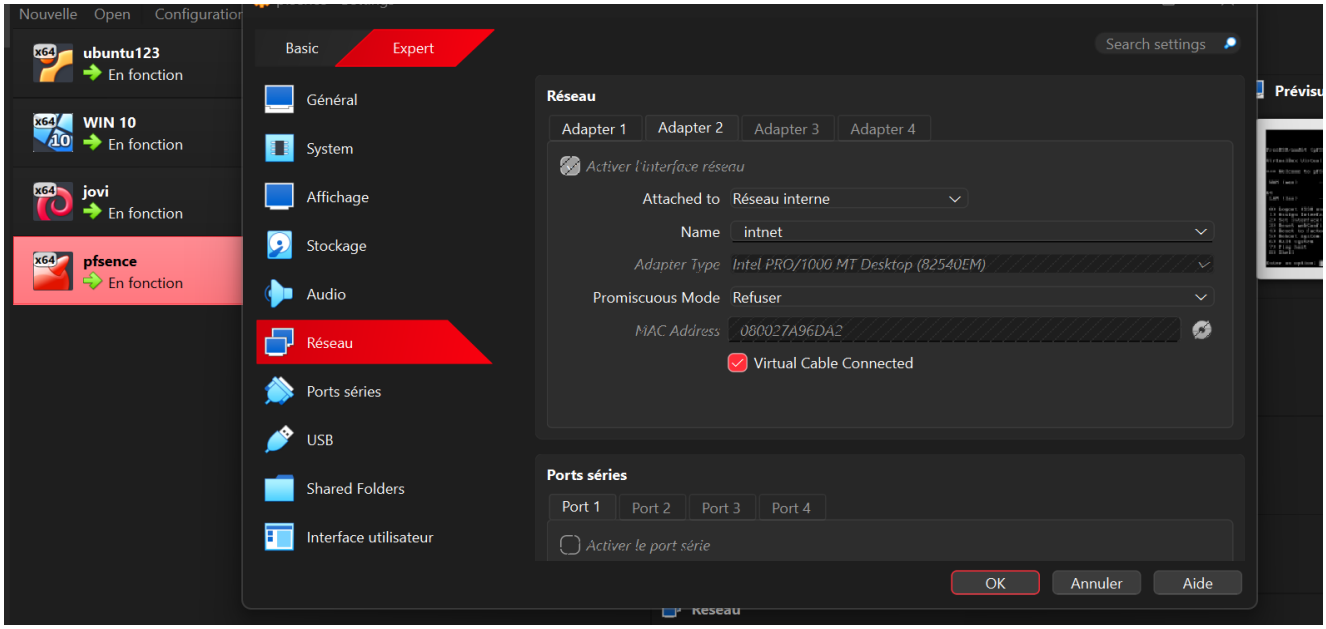
- Contrôler les flux entre le réseau interne (LAN) et l'extérieur (WAN).
- Restreindre les services accessibles (ex: limiter au port 80).
- Simuler des comportements d'attaquants pour vérifier l'efficacité des règles.

2. Architecture du Laboratoire

Zone WAN : Accès à Internet via NAT.



Zone LAN : Réseau interne (Host-Only) contenant les machines Ubuntu et Windows.

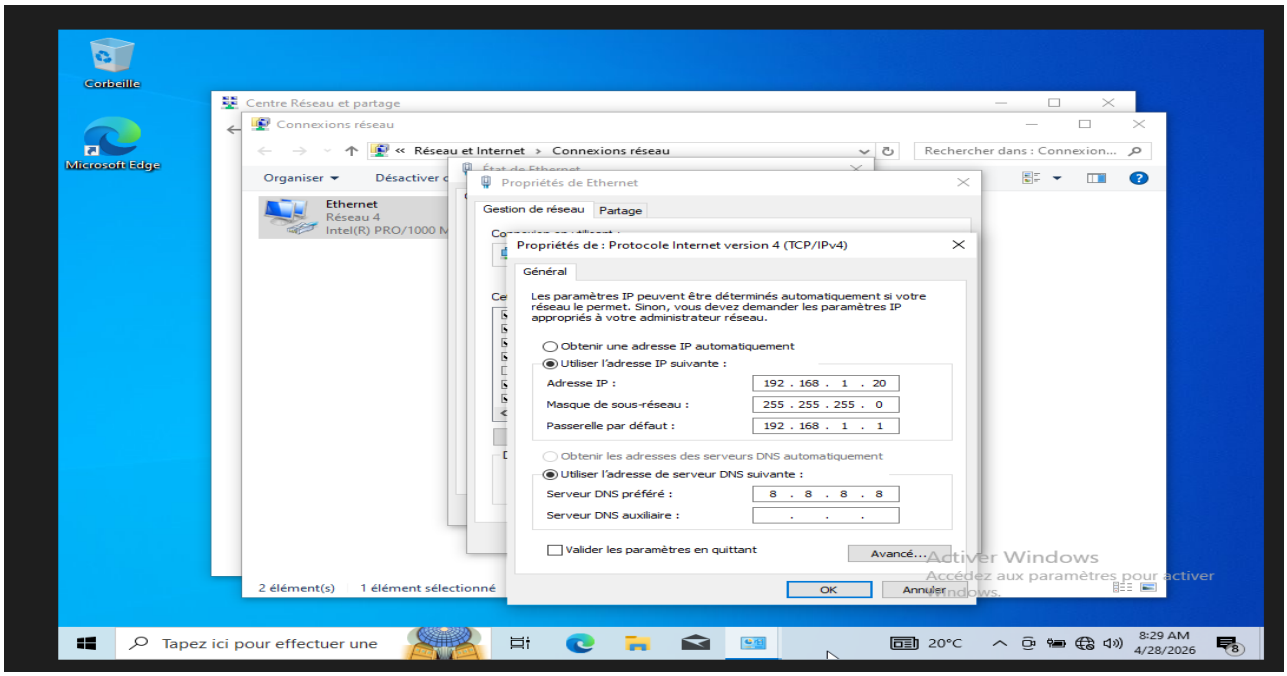


Le Pare-feu : pfSense, faisant le pont entre les deux zones.

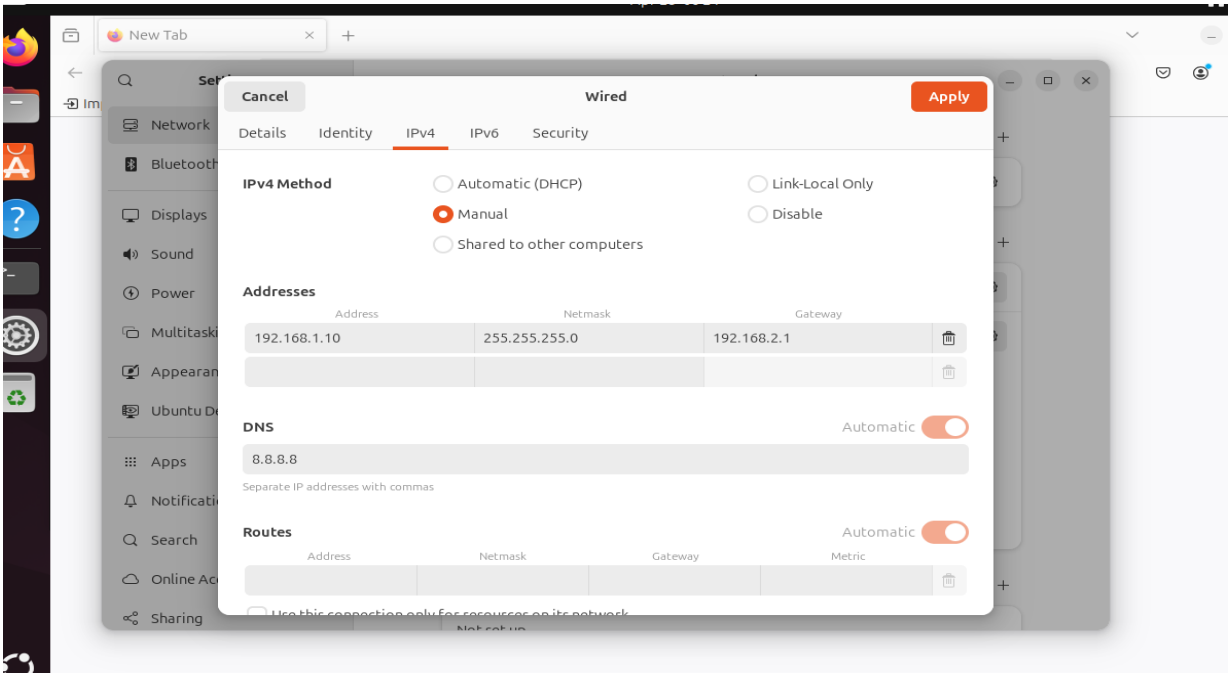
3. Déroulement des Étapes et Résultats

❖ Étape 5 & 6 : Configuration IP et Connectivité

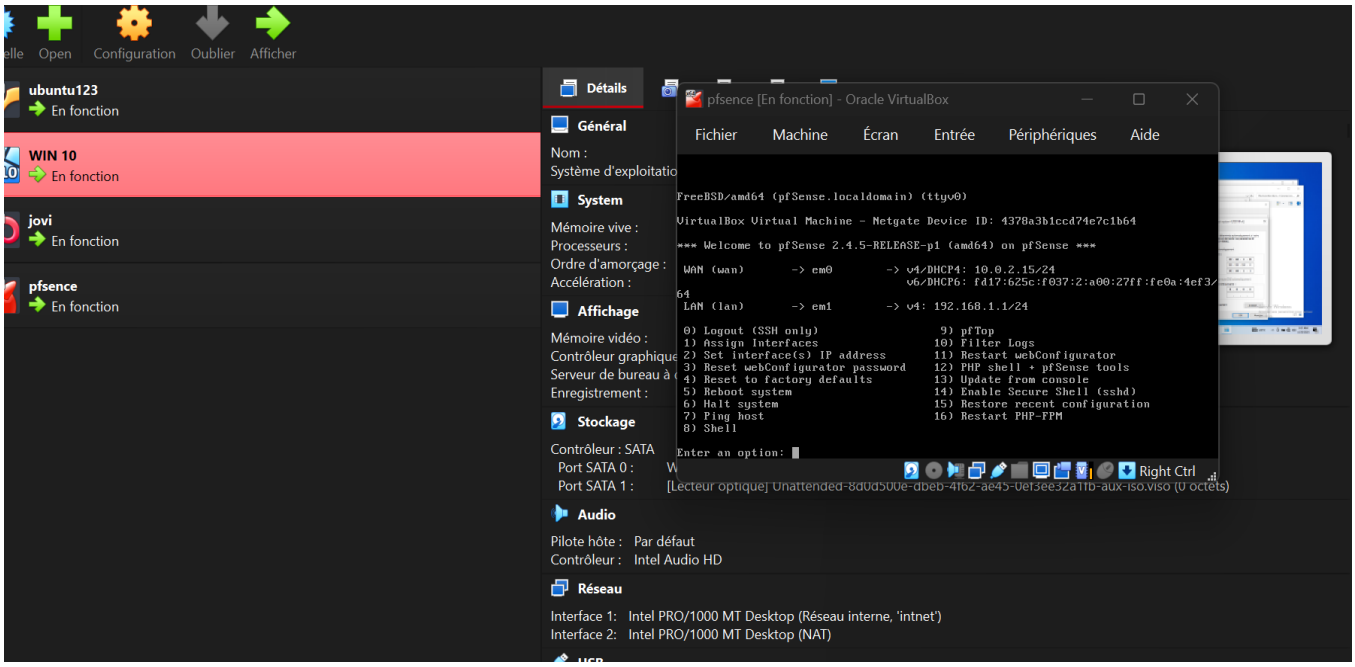
1. **Cas de Windows**
2. Configuration Windows :IP statique : 192.168.1.20/24
3. Passerelle (Gateway) : 192.168.1.1



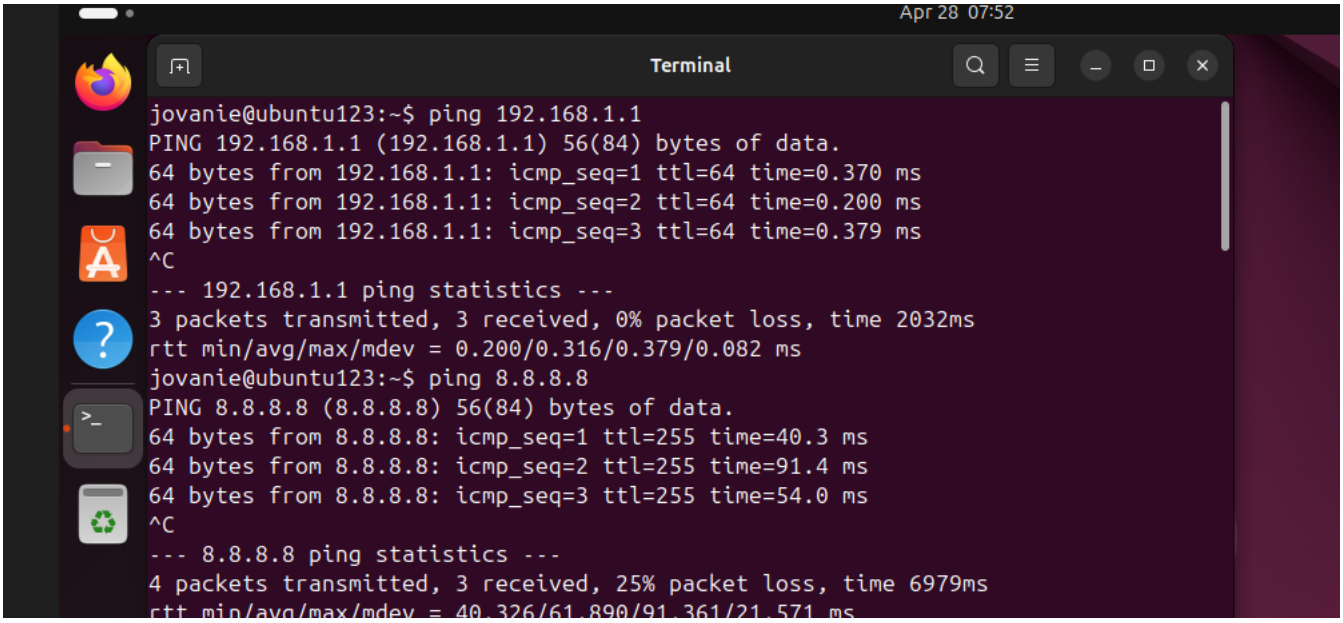
4. **Cas de Ubuntu**
   - Configuration Ubuntu :IP statique : 192.168.1.10/24
   - Passerelle (Gateway) : 192.168.1.1



❖ **Configuration pfSense : L'interface LAN a été configurée avec l'adresse IP 192.168.1.1** : qui est l'adresse par défaut de **Pfsense**

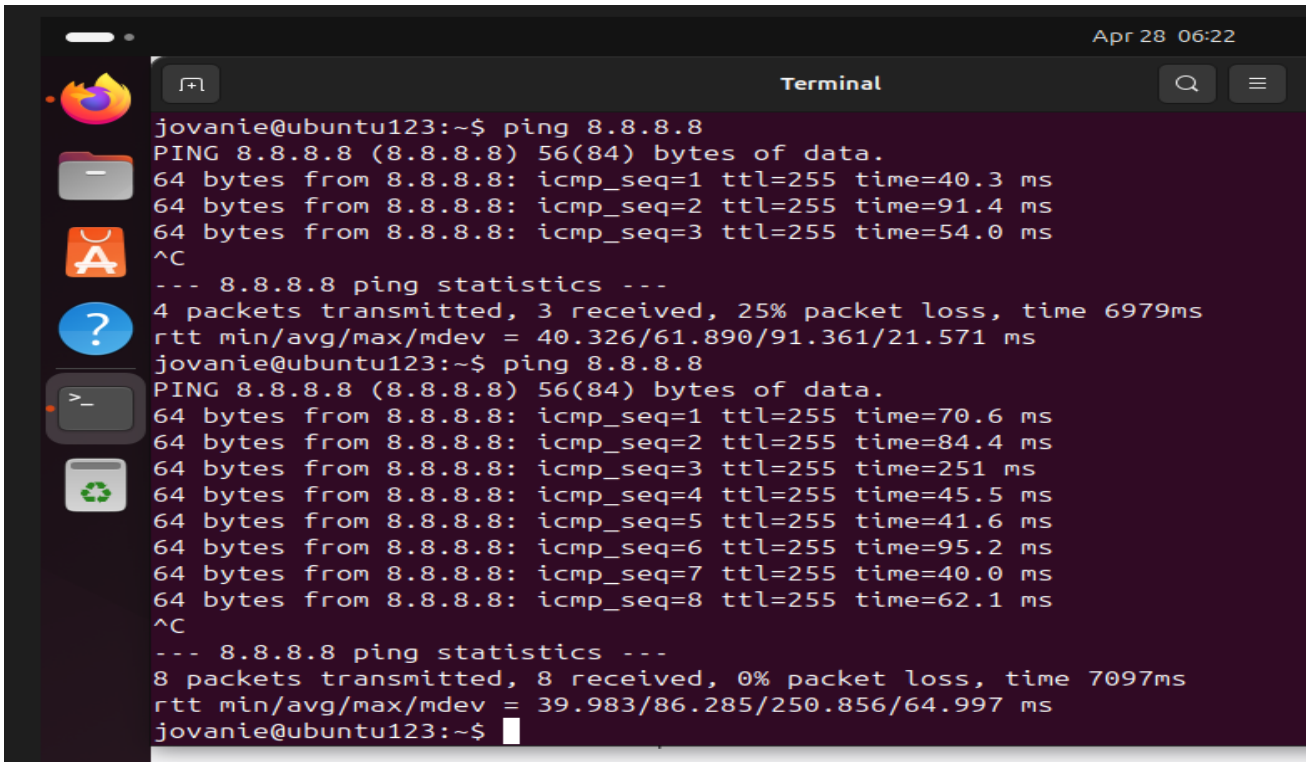


Vérification : **Le Ping 192.168.1.1** depuis Ubuntu confirme que la machine communique bien avec le pare-feu.

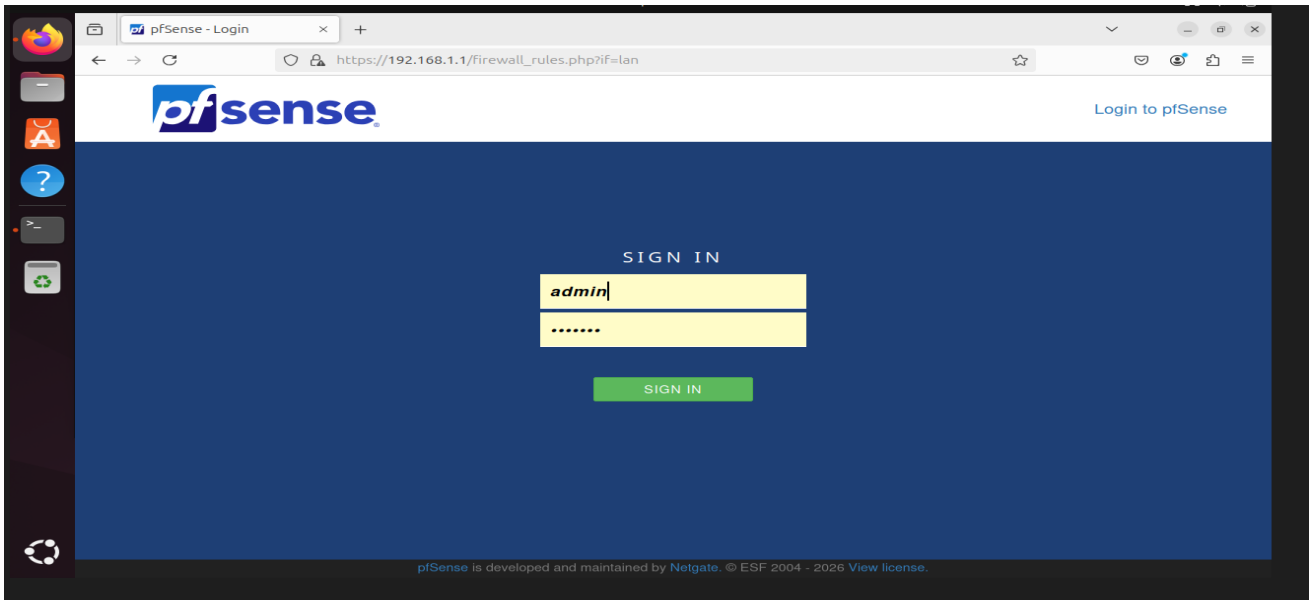


Étape 8 & 9 : Test du Routage et Mise en place du Filtrage

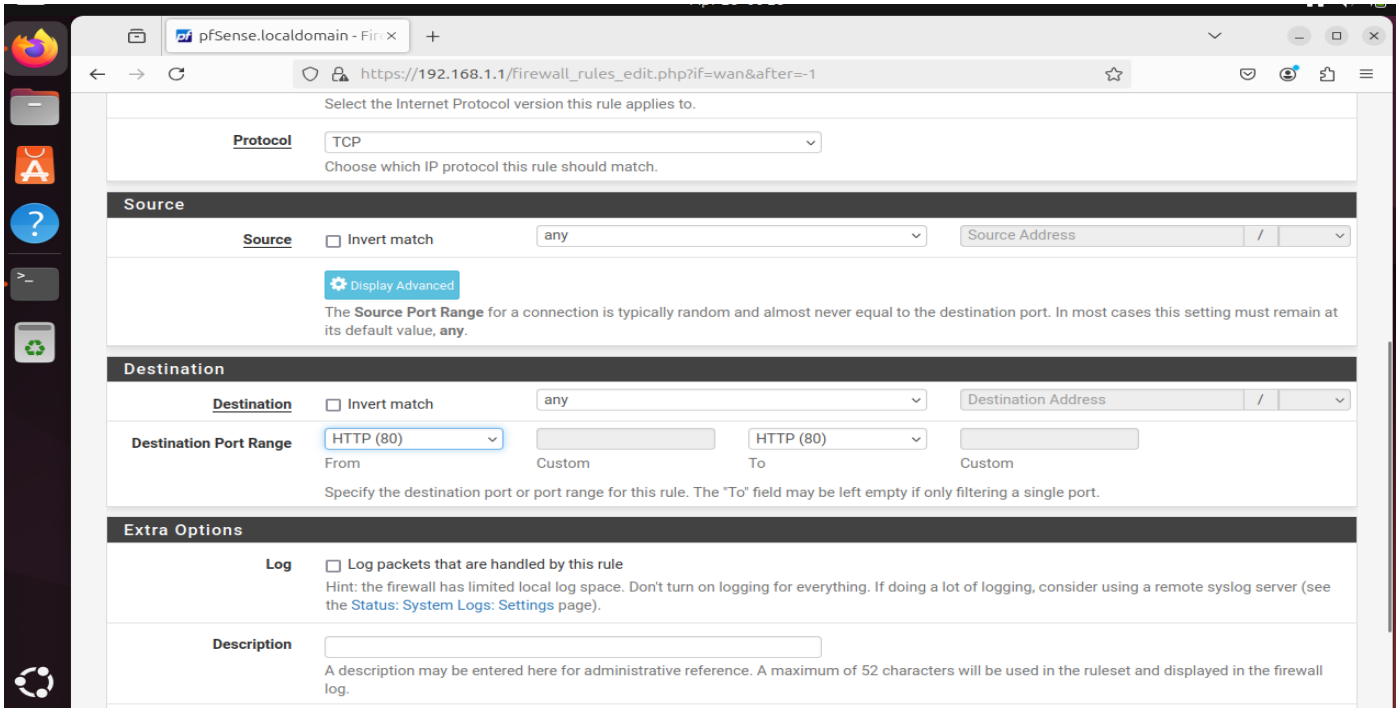
1. Avant filtrage : Le ping 8.8.8.8 fonctionne car pfSense autorise tout par défaut au début.



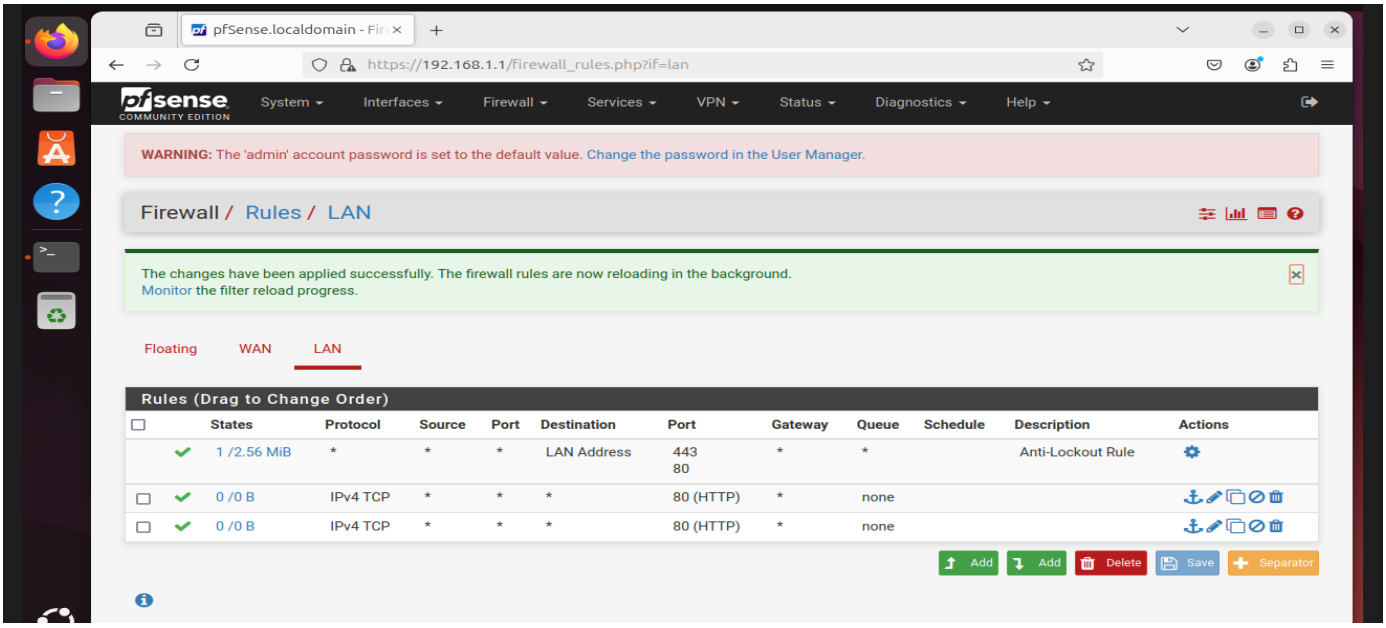
2. Mise en place de la restriction : Désactivation de la règle "**Default allow LAN to any**" : Avant cela nous avons établir une connexion avec un **login et mot de passe**



❖ Création d'une règle spécifique : Action <Pass | Interface: LAN | Protocol: TCP | Port: 80 (HTTP)>.

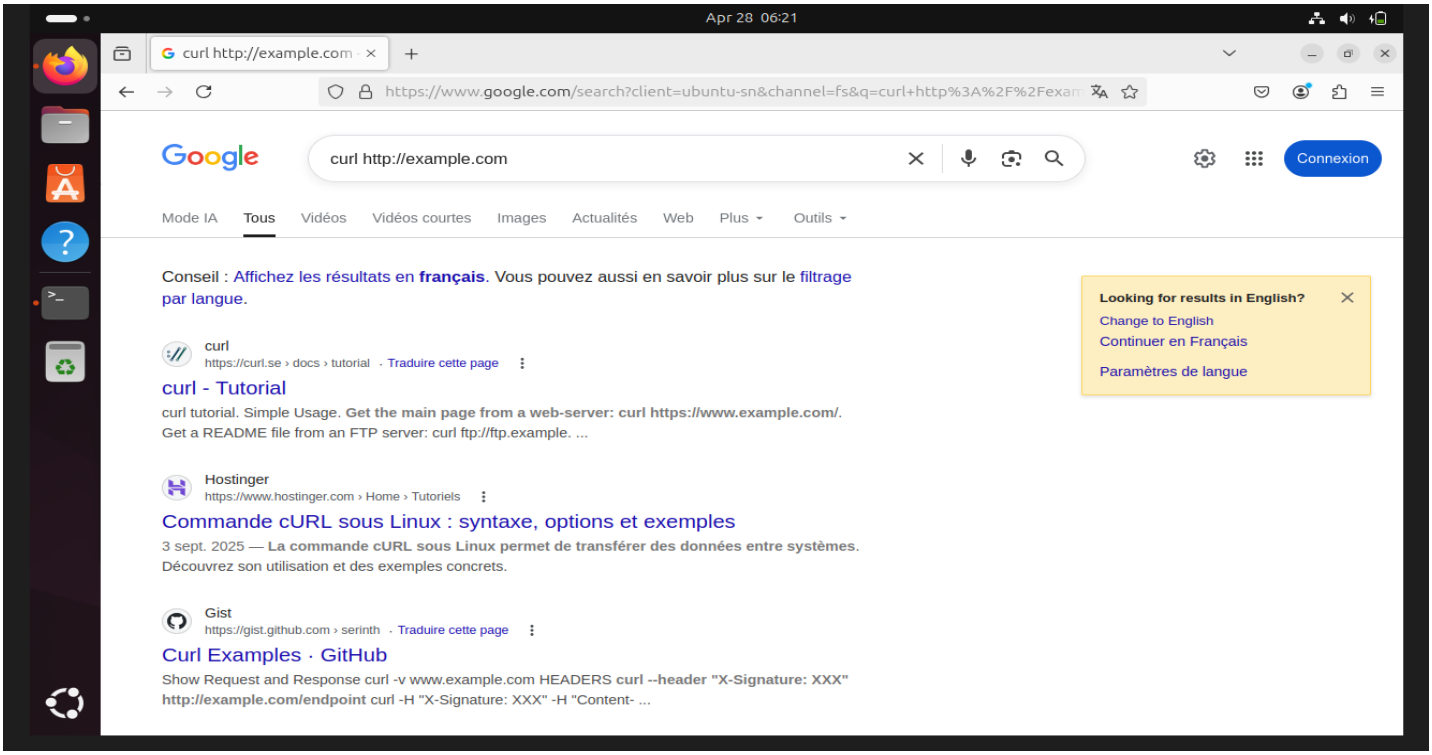


3. Conséquence : Seul le trafic web sur le port 80 est maintenant autorisé.

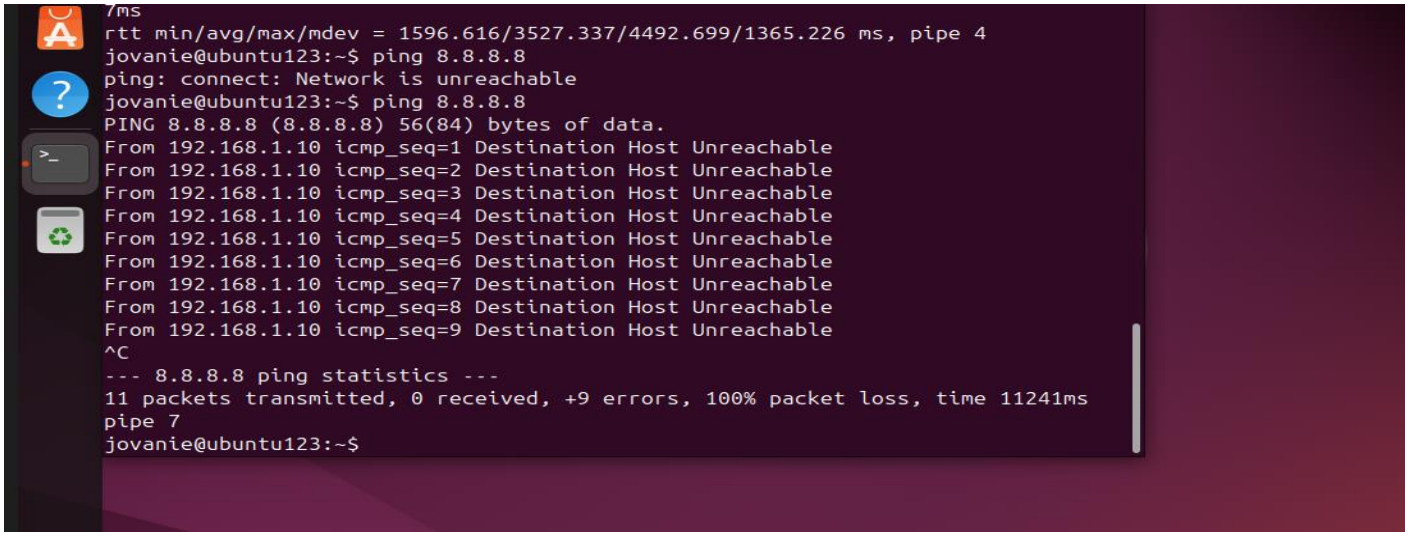


Étape 10 : Tests de fonctionnement (Validation)

Test HTTP : La commande **curl http://example.com** fonctionne (le port 80 est ouvert).



Test ICMP : La commande **ping 8.8.8.8** échoue (Destination Host Unreachable).



Observation : C'est le comportement attendu car nous n'avons pas créé de règle pour autoriser le protocole ICMP.

4. Simulation d'un comportement attaquant

En tentant un scan avec **nmap** ou une tentative de connexion SSH depuis une machine compromise :

Commande : **nmap -sS 8.8.8.8**

Résultat : Le scan échoue ou ne renvoie aucun résultat valide.

Interprétation : Le pare-feu bloque efficacement les communications non autorisées, empêchant ainsi une machine compromise de communiquer avec un serveur de commande (C2) externe sur des ports autres que le 80.

5. Analyse et Améliorations (Réponses aux questions du TP)

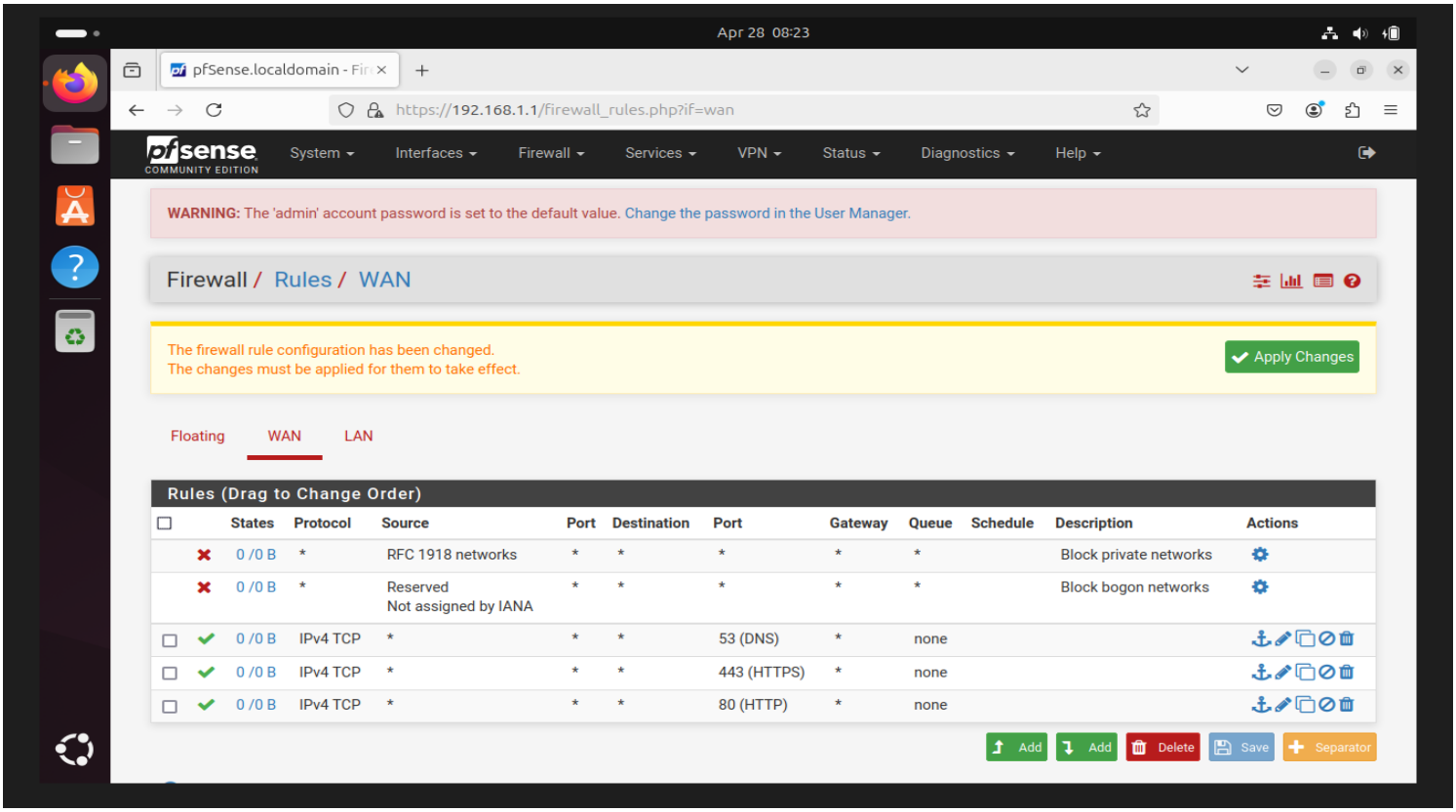
Pourquoi la règle fonctionne Elle utilise l'inspection de paquets pour ne laisser passer que les segments TCP dont la destination est le port 80.

Ce qu'elle autorise : La navigation web non sécurisée (HTTP).

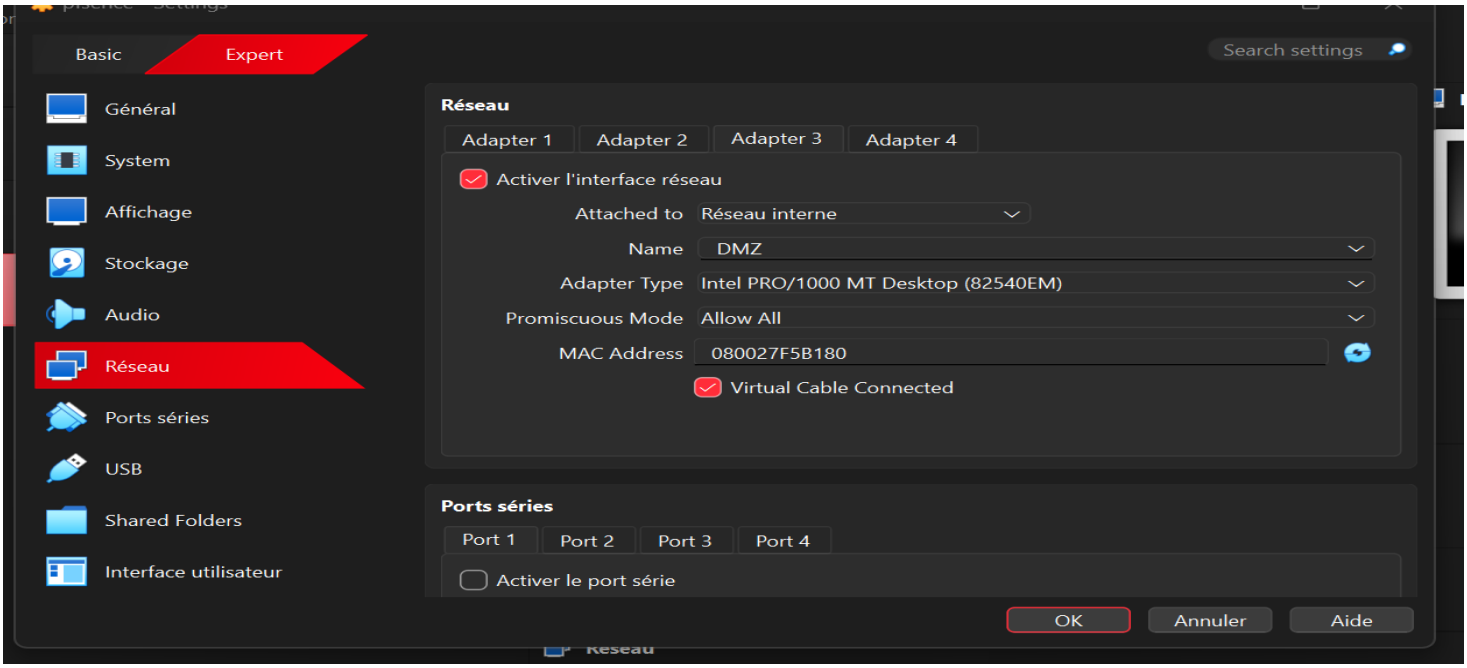
Ce qu'elle bloque : Le Ping (ICMP), le SSH (22), le DNS (53) s'il n'est pas configuré, et tout autre protocole non spécifié.

Améliorations a proposées :

1. **Autoriser le HTTPS** : Ajouter une règle pour le port 443 afin de permettre la navigation sécurisée.
2. **DNS** : Autoriser le port **53 (UDP)**vers les serveurs DNS pour que les noms de domaine (comme google.com) soient résolus.



3. **DMZ** : Ajouter une zone DMZ pour isoler les serveurs accessibles de l'extérieur.



Conclusion

Ce TP démontre que la segmentation réseau est la première ligne de défense en cybersécurité. Même si une machine du LAN est compromise, pfSense limite drastiquement les capacités de mouvement de l'attaquant grâce à une politique de "moindre privilège".